Chapter 03 대칭키 암호(3)

Venture1st 호서대학교

블록 암호의 활용

- 블록 암호 알고리즘을 이용하여 다양한 암호학적 메커니즘 구현 가능
  - 블록 기반의 메시지 암호화 방식
  - 스트림 암호 방식
  - 메시지 인증 코드(MAC)
  - 키 교환 프로토콜 구성 등

3.3 블록 암호 – 블록 암호 모드

- 임의의 길이의 평문을 암호화하기 위해서는 평문을 일정한 길이를 갖는 블록으로 나누고 각 블록에 블록 암호를 반복 적용
- 블록 암호를 반복하는 방법을 블록 암호의 **운영 모드(mode of operation)**라 함

  - ECB(Electronic Codebook) 모드
  - CBC(Cipher Block Chaining) 모드
  - CFB(Cipher Feed Back) 모드
  - OFB(Output Feed Back) 모드
  - CTR(Counter) 모드

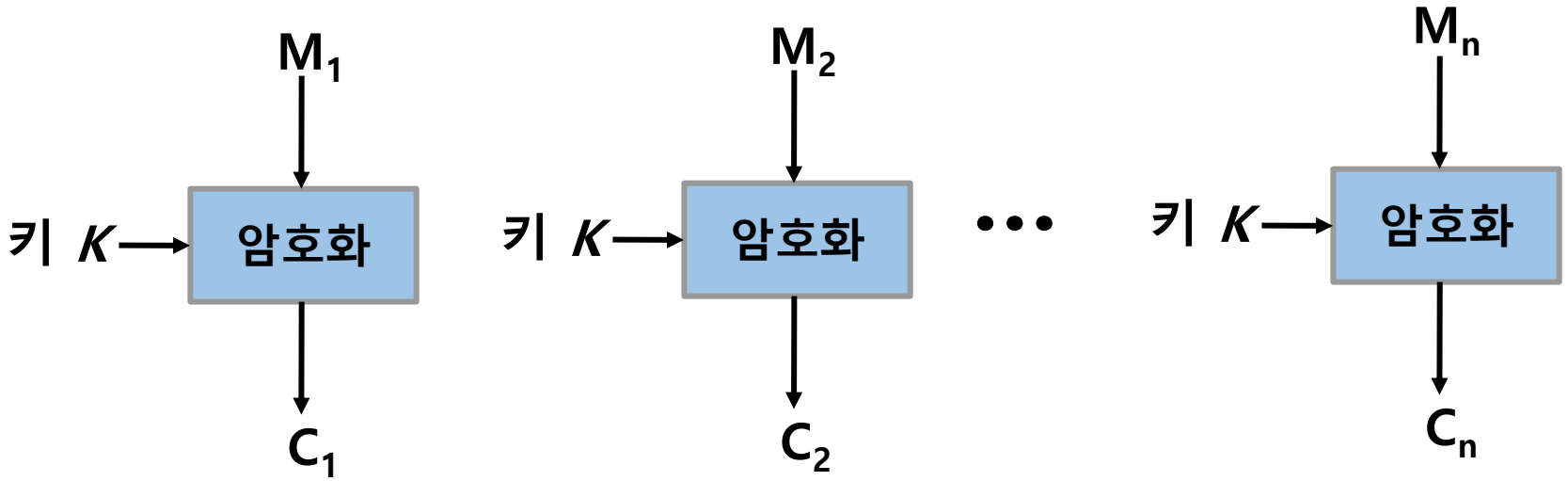
3.3 블록 암호 – ECB 모드

➢ ECB 모드

- 전자 코드북(ECB; Electronic Codebook) 모드
- 평문을 일정한 크기의 블록으로 나누어 동일한 키를 이용하여 암호화
- M_n이 블록 암호 시스템의 입력 크기보다 작은 경우 패딩 수행

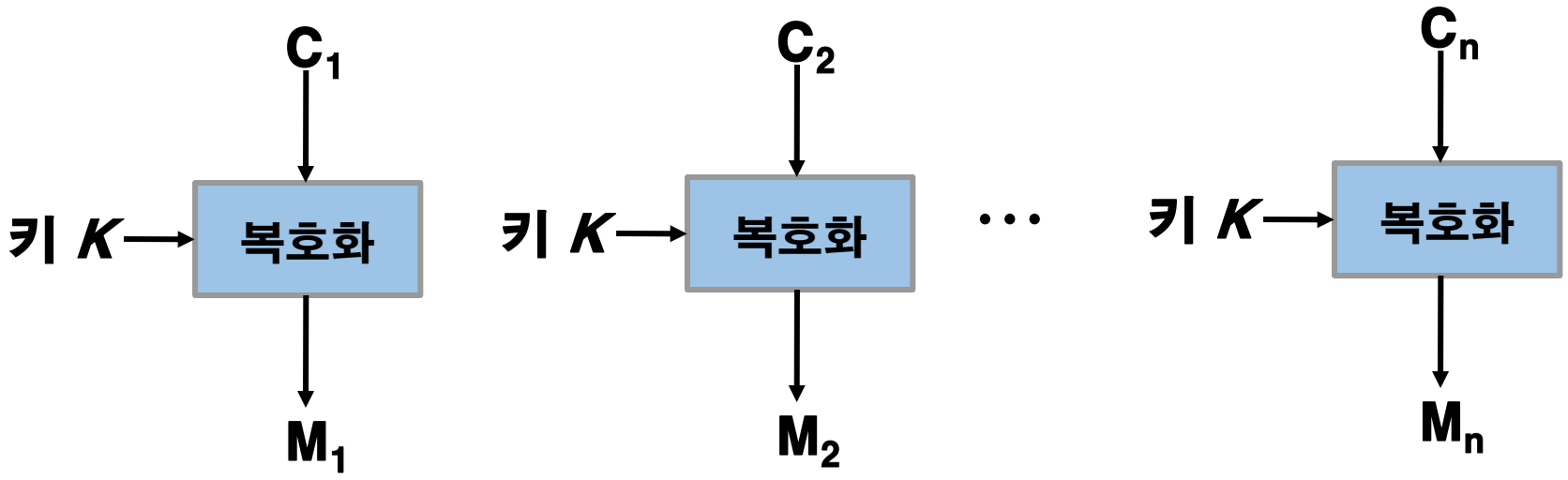
암호화 $C_i = E_K(M_i)$

(단, 평문 $M = M_1M_2M_3 \ldots M_n$)



ECB 3.3 블록 암호 – ECB 모드

복호화 $M_i = E_K(C_i)$



ECB 3.3 블록 암호 – ECB 모드

➢ 장점

- 암호화된 모든 블록을 수신하지 않더라도 수신한 블록만 복호 가능
- 특정 블록에 에러가 발생하는 경우, 해당 블록에만 영향을 미침
- 병렬 구현이 가능하므로 고속화 구현에 적절

➢ 단점

- 동일한 평문에 대해 동일한 암호문 출력
- 평문 블록과 암호문 블록이 일대일 관계(코드 북)

➢ 주로 짧은 길이의 평문이나 키 암호화에 사용

3.3 블록 암호 – ECB 모드

➢ 압축되지 않은 앨리스 이미지와 ECB 모드로 암호화된 앨리스 이미지

(a) 앨리스

(b) ECB 모드로 암호화된 앨리스

- 두 픽셀의 값이 같으면, 암호화된 두 값 역시 동일
- 모든 검은색 픽셀을 암호화하면 모두 색 A가 되고, 모든 흰색 픽셀을 암호화하면 모두 색 B가 됨
- 공격자가 암호문으로부터 평문을 추정하는 것이 어렵지 않음

3.3 블록 암호 – ECB 모드

➢ [예제] 전자 예금 이체에 대한 대체 공격

[공격 환경]

- 계좌 이체를 위해 다음과 같이 5개의 필드를 사용하고, 각 필드의 크기가 블록 암호의 입력 블록크기와 동일하다고 가정
- 두 은행 사이의 암호화 키는 주기적으로 변경되지만, 전송 될 때마다 변경되지는 않음
- 공격자는 은행 A에서 전송되는 암호화된 데이터를 도청할 수 있고, 특정 블록을 다른 블록으로 대체하는 공격 가능

M1	M2	M3	M4	M5
송신은행 A	송신 계좌 번호	수신은행 B	수신 계좌 번호	금액 $

3.3 블록 암호 – ECB 모드

➢ 공격 시나리오

[전제조건]

① 공격자는 은행 A와 B에 계좌를 개설한다.

② 두 은행 사이의 동일한 암호화 키가 한동안 사용된다.

③ 공격자는 은행 사이의 전송되는 암호화된 데이터를 도청할 수 있다.

[공격 과정]

① 공격자는 은행 A의 자신의 계좌에서 은행 B의 자신의 계좌로 $1.00을 이체한다.

② 공격자를 암호문 블록을 복호화 할 수는 없지만, 자신이 이체를 수행한 후 전송되는 암호문 블록 C1,C3,C4를 저장한다.(공격자의 두 은행의 ID와 공격자의 B은행 계좌번호)

③ 공격자는 은행 A에서 이체를 위해 전송하는 암호문 블록을 관찰하다가, 은행 A에서 은행 B로 이체되는 거래를 발견하는 경우, 블록 C4를 저장한 블록(자신의 계좌번호)으로 대체한다.

④ 은행 A의 어떤 계좌로부터 공격자의 계좌로 자금이 이체되지만, 은행 B는 이를 탐지할 수 없다.

3.3 블록 암호 – ECB 모드

① 공격자는 자신의 A은행의 계좌에서 B은행의 계좌로 $1.00 이체

M1	M2	M3	M4	M5
송신은행 A	공격자의 A은행 계좌번호	수신은행 B	공격자의 B은행 계좌 번호	금액 $1.00

C1	C2	C3	C4	C5
송신은행 A	공격자의 A은행 계좌번호	수신은행 B	공격자의 B은행 계좌 번호	금액 $1.00

암호화된 이체 데이터

② 암호문 블록 C1, C3, C4 저장

3.3 블록 암호 – ECB 모드

③ 은행 A에서 이체되는 암호문 블록을 계속 도청하여 B은행으로 이체하는 것을 발견한 경우, C'4를 저장해 놓은 C4로 바꾸는 대체 공격 수행

C1	C2	C3	C4	C5
송신은행 A	공격자의 A은행 계좌번호	수신은행 B	공격자의 B은행 계좌 번호	금액 $1.00

저장해 놓은 암호화된 데이터

C1=C'1이고 C3=C'3인 경우, 은행 A에서 은행 B로 이체되는 데이터임을 알 수 있음

C'1	C'2	C'3	C'4	C'5
송신은행 A	Alice의 A은행 계좌번호	수신은행 B	Bob의 B은행 계좌 번호	금액 $1000

B은행으로 이체하는 새로운 데이터

※단, 두 개의 암호문은 동일한 키로 암호화되어 있음

3.3 블록 암호 – ECB 모드

원래의 이체 데이터(암호문)

C'1	C'2	C'3	C'4	C'5
송신은행 A	Alice의 A은행 계좌번호	수신은행 B	Bob의 B은행 계좌번호	금액 $1000

공격자의 B은행 계좌번호

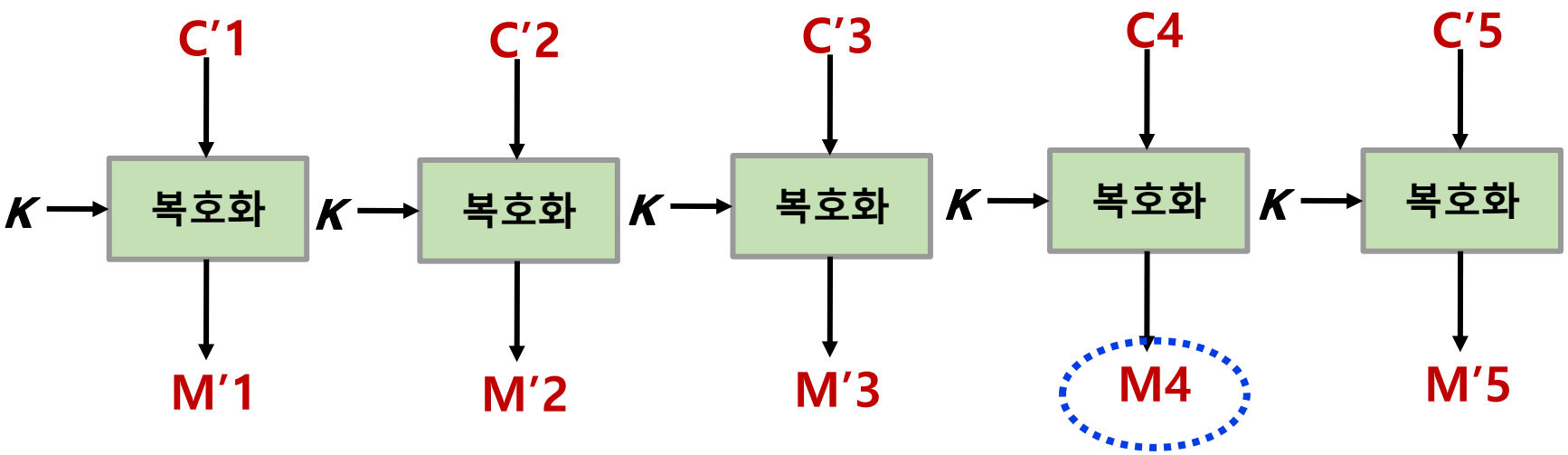
저장해 놓은 블록 C4로 대체

대체공격 후 이체 데이터(암호문)

C'1	C'2	C'3	C4	C'5
송신은행 A	Alice의 A은행 계좌번호	수신은행 B	공격자의 B은행 계좌번호	금액 $1000

3.3 블록 암호 – ECB 모드

➢ 복호화 과정



M'1	M'2	M'3	M4	M'5
송신은행 A	Alice의 A은행 계좌번호	수신은행 B	공격자의 B은행 계좌 번호	금액 $1000

Alice의 계좌에서 공격자의 계좌로 이체 성공!!!

3.3 블록 암호 – ECB 모드

- 대체 공격은 블록 암호 알고리즘 자체를 공격하는 것이 아님
- 따라서, 긴 길이의 키를 사용하는 암호 알고리즘을 사용하더라도 이 공격을 막을 수 없음

- 공격자는 메시지의 내용은 모르는 상태에서 블록들을 대체 시키는 공격만 수행
- 메시지 블록을 대체하는 경우에도 복호화가 정상적으로 가능하므로 메시지의 기밀성을 유지되지만, 메시지의 무결성이 보장되지 않음
- 따라서, ECB 모드는 짧은 길이의 메시지를 암호화할 때만 사용

- 해결책
  - 동일한 평문이라도 암호화 할 때마다 다른 암호문 생성하는 모드 사용
  - 은행 A와 B사이에 키는 연결마다 변경되어야 함

3.3 블록 암호 – CBC 모드

➢ CBC(Cipher Block Chaining mode) 모드

- 이전 블록의 암호문이 다음 평문 블록 암호화에 영향을 미치도록 함
- 이전 블록의 결과로 출력된 암호문 블록에 현재 평문 블록을 XOR 하고 나서 암호화 수행
- 생성되는 각각의 암호문 블록은 현재 평문 블록 뿐만 아니라 그 이전의 평문 블록들의 영향도 받게 됨

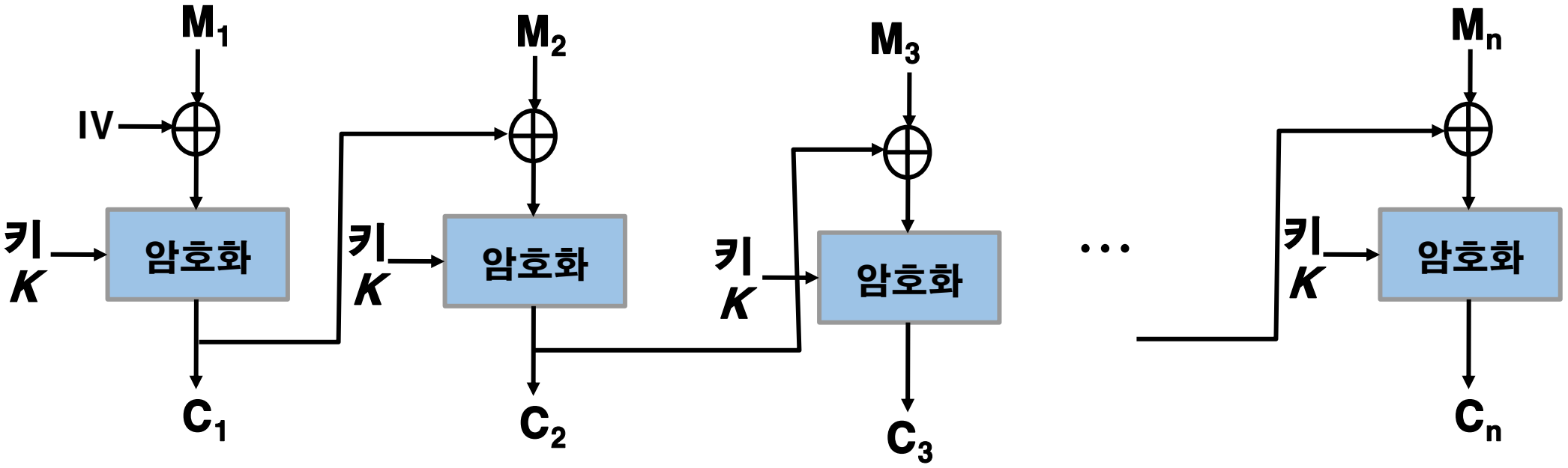
➢ 초기 벡터(initialization vector) 사용

- 첫 번째 평문 블록을 암호화할 때는 이전 블록이 존재하지 않으므로, 대신할 한 개의 블록 필요
- 비밀키와 마찬가지로 송신자와 수신자간에 미리 약속되어 있어야 하지만 공개된 값을 사용해도 무방
- 단, 한번만 사용되는 값이어야 함

3.3 블록 암호 – CBC 모드

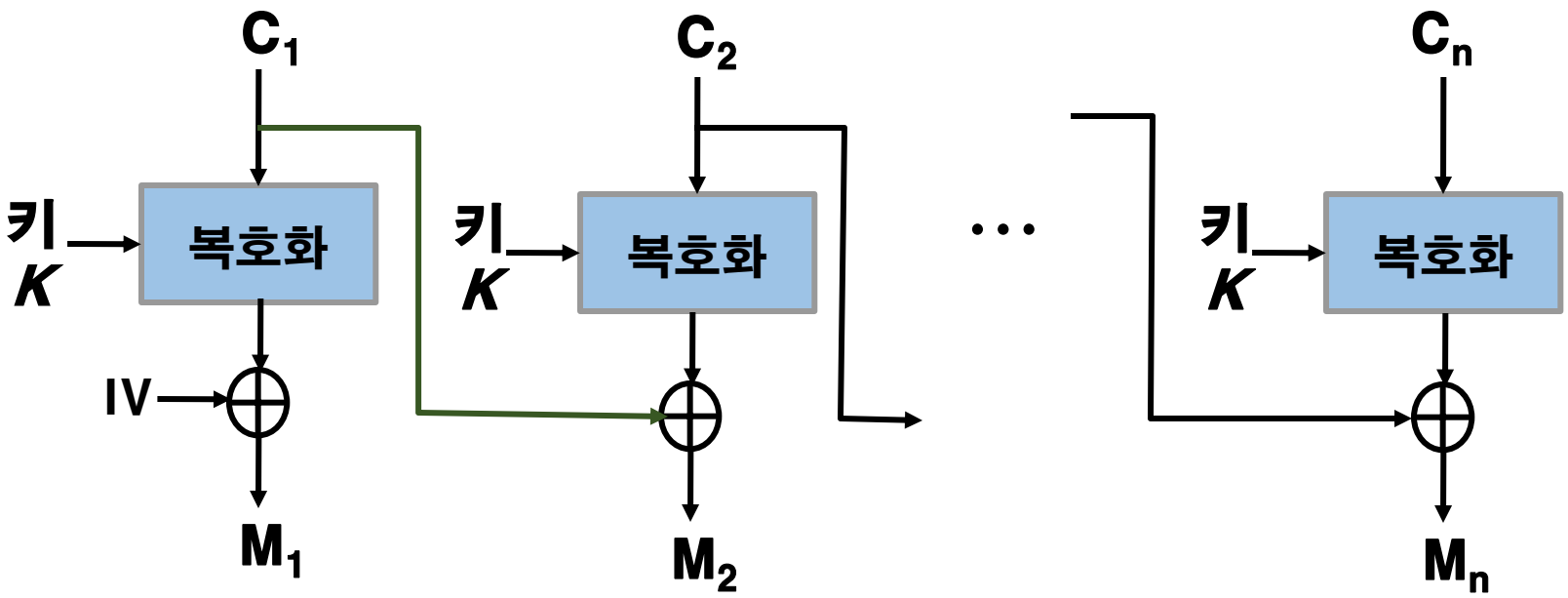
암호화 $C_i = E_K(M_i \oplus C_{i-1})$ 단, $C_0 = IV$

평문 $M = M_1M_2M_3 \ldots M_n$



3.3 블록 암호 – CBC 모드

복호화 $M_i = D_K(C_i) \oplus C_{i-1}$ 단, $C_0 = IV$



3.3 블록 암호 – CBC 모드

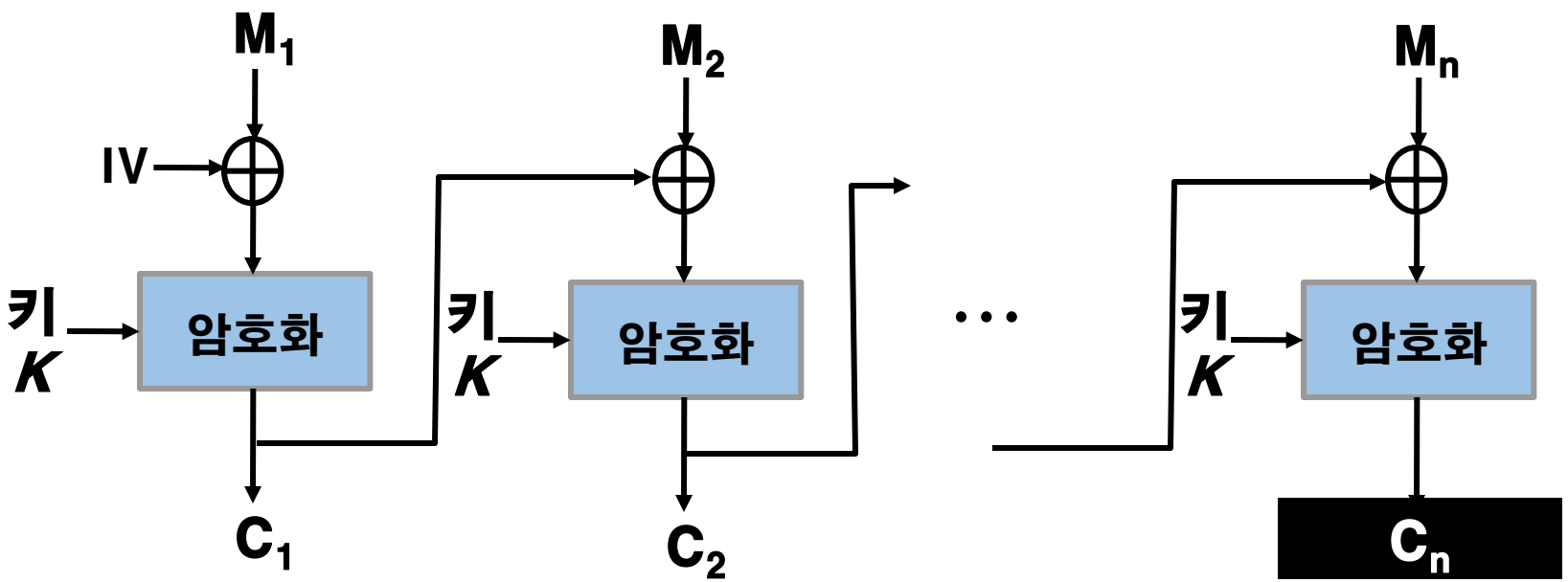
- 동일한 평문에 대해 서로 다른 암호문 생성

- 암호문 블록 C_i에서 한 비트 오류 발생
  - 해당 평문의 M_i의 여러 비트에 영향
  - 다음 단의 평문 블록 M_{i+1}의 한 비트 오류 발생

- 평문 블록 M_i에서 오류 발생
  - 다음에 출력되는 모든 암호문 C_i, C_{i+1}, C_{i+2}, …에 영향을 미침
  - 에러 전파(error propagation) 특성으로 메시지 인증코드(MAC)로 이용

3.3 블록 암호 – CBC 모드

➢ CBC 모드를 이용한 메시지 무결성 확인 방법



- 특정 블록 평문의 한 비트가 변경되면 가장 마지막 블록까지 영향을 미침

3.3 블록 암호 – CBC 모드

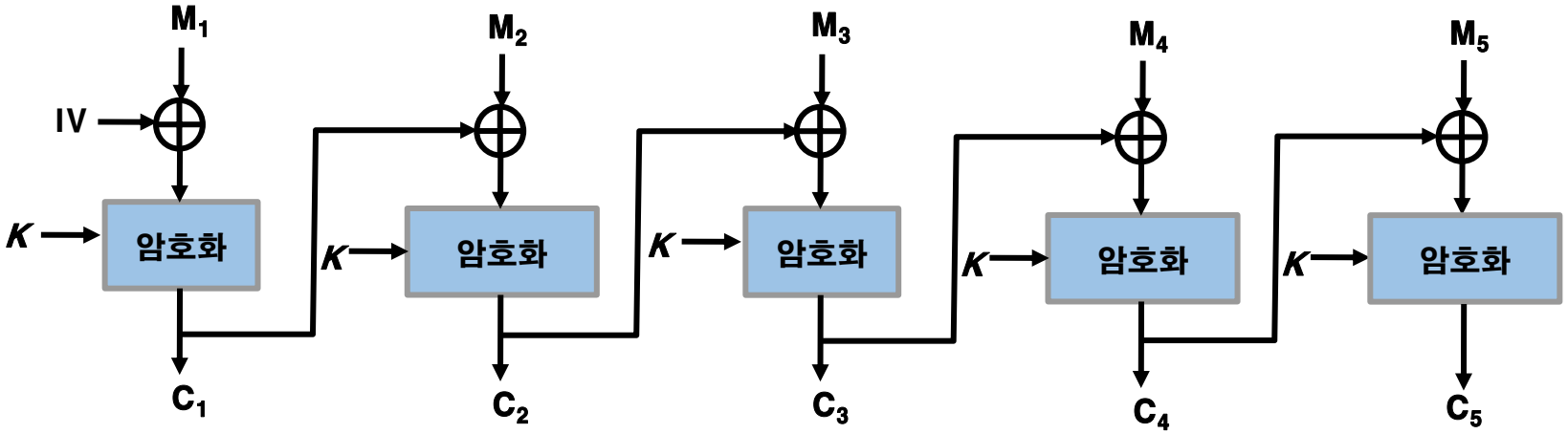
- **CBC 모드를 이용한 메시지 무결성 확인 방법(기밀성은 제공X)**
  ① 송신자는 메시지 $M = M_1M_2M_3 \ldots M_n$ 과 CBC 모드로 생성한 암호문 **마지막 블록 C_n을 수신자에게 전송**
  ② 수신자는 M에 대해 CBC 모드를 이용하여 암호화 수행
  ③ 수신자가 생성한 암호문의 마지막 블록와 송신자에게 받은 C_n이 동일한지 확인

- **평문 1비트의 변경이 마지막 암호문 블록까지 영향을 미침**
  - 수신자가 생성한 마지막 블록과 송신자가 보낸 블록이 같으면 메시지는 변경되지 않았음을 보장(무결성 확인)

3.3 블록 암호 – CBC 모드

➢ CBC 모드에서는 대체 공격이 가능할까?

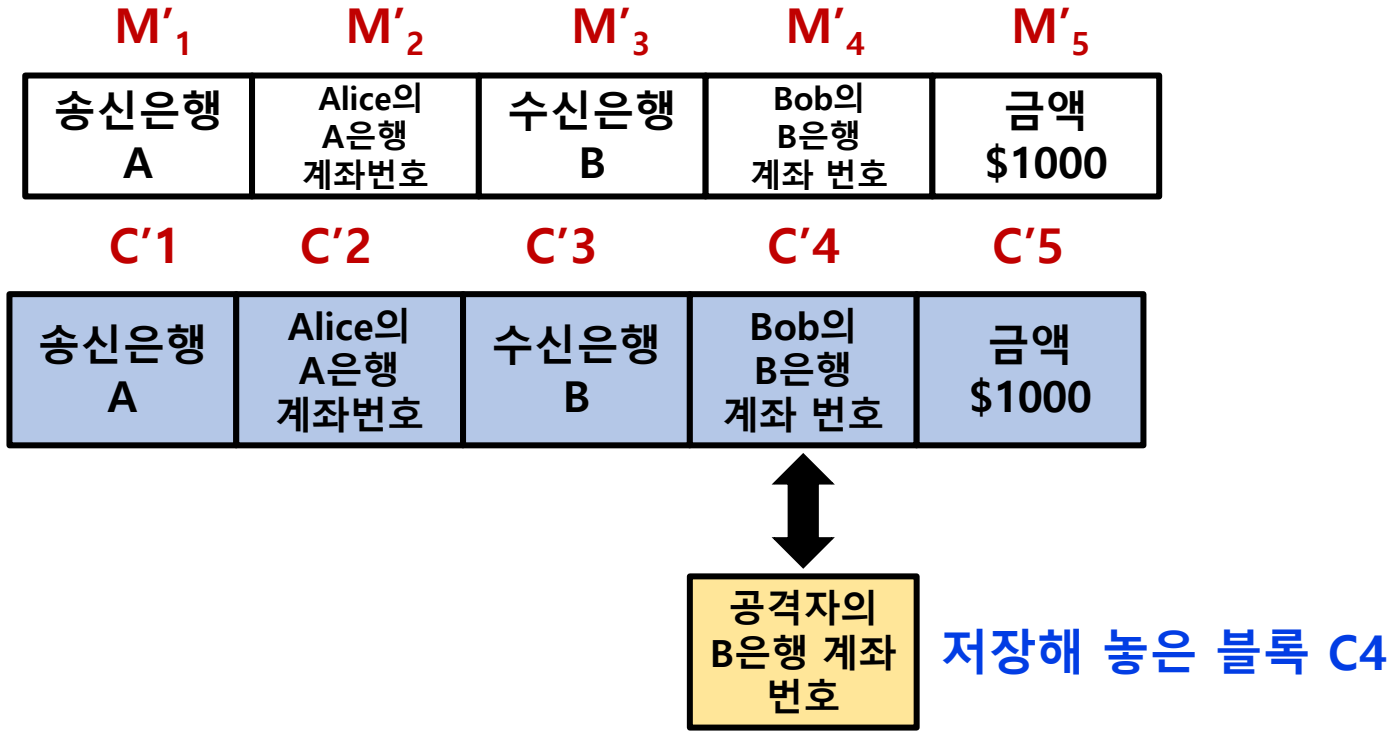
M_1	M_2	M_3	M_4	M_5
송신은행 A	공격자 송신 계좌번호	수신은행 B	공격자 수신 계좌 번호	금액 $1



C_1	C_2	C_3	C_4	C_5
송신은행 A	공격자 송신 계좌번호	수신은행 B	공격자 수신 계좌번호	금액 $1

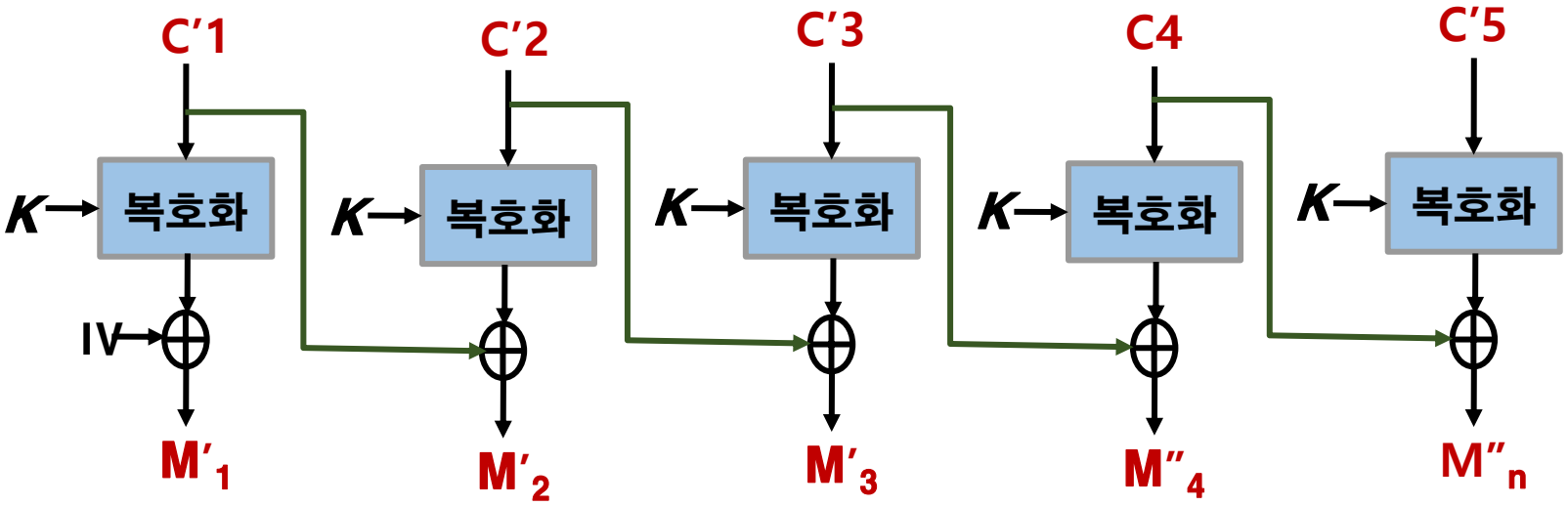
3.3 블록 암호 – CBC 모드

- 암호화된 블록 C4만 대체하는 경우, 원하는 대로 공격자의 계좌로 이체가 가능한가?
  - 암호문을 생성할 때 마다 서로 다른 IV를 사용하면, 암호문으로부터 어떠한 패턴도 알아낼 수 없으므로, 대체 공격 수행 불가능!!!
  - 동일한 IV를 사용한 경우에 A은행에서 B 은행으로의 이체를 알 수 있음



3.3 블록 암호 – CBC 모드

➢ 복호화 과정



C4를 복호화하여 M4(공격자의 계좌번호)가 나오려면
C3가 필요한데, 복호화 시 C'3와 XOR 연산을 하였으므로
다른 계좌번호(M''_4)가 복호화 결과로 나옴

- 원하는 계좌로의 이체는 불가능하지만, Bob의 계좌가 아닌 다른 계좌로 이체가 일어날 수 있음
- 따라서, 기밀성 뿐만 아니라 무결성 보장이 필요함

3.3 블록 암호 – CBC 모드

[장점]

- 동일한 평문이라도 암호화할 때 마다 **서로 다른 암호문 생성**(단, 암호화 시 마다 서로 다른 초기벡터 사용)
- 평문 블록 중 어느 곳이든 1비트만 변경되더라도 암호문의 마지막 블록까지 영향을 미치므로 **메시지 인증 코드로 사용** 가능
- 특정 블록만 변경하는 대체 공격 불가능

[단점]

- 암호화 시 이전 블록의 암호문이 필요하므로 병렬 구현 불가능

3.3 블록 암호 – CFB 모드

➢ CFB(Cipher FeedBack) 모드

- Cipher FeedBack 모드(암호 피드백 모드)
- 이전 암호문 블록을 다음 단계 암호 알고리즘의 입력으로 사용(초기 벡터 필요)
- 블록 암호 알고리즘을 이용하여 스트림 암호를 구현

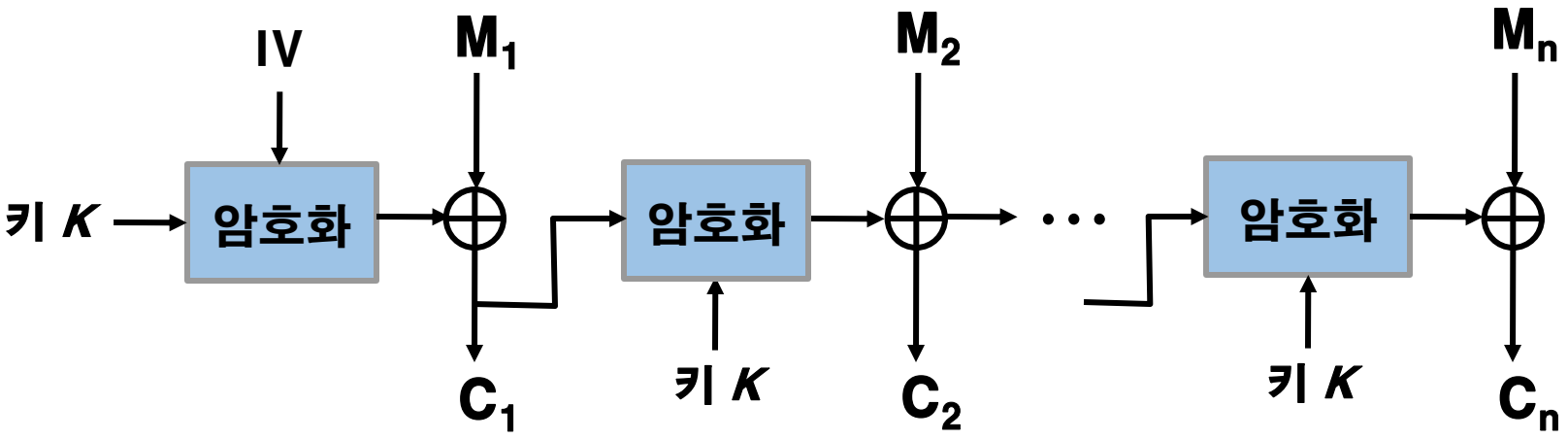
➢ 특징

- 동일한 평문 블록에 대해 동일한 암호문이 나타나지 않도록 함
- 평문 블럭내에 한 비트 오류가 발생하면 모든 암호문에 영향을 미침
- 암호문 블럭내에 한 비트 오류가 발생하면 복호화된 모든 평문에 영향을 미침

3.3 블록 암호 – CFB 모드

암호화 $C_i = E_K(C_{i-1}) \oplus M_i$ 단, $C_0 = IV$

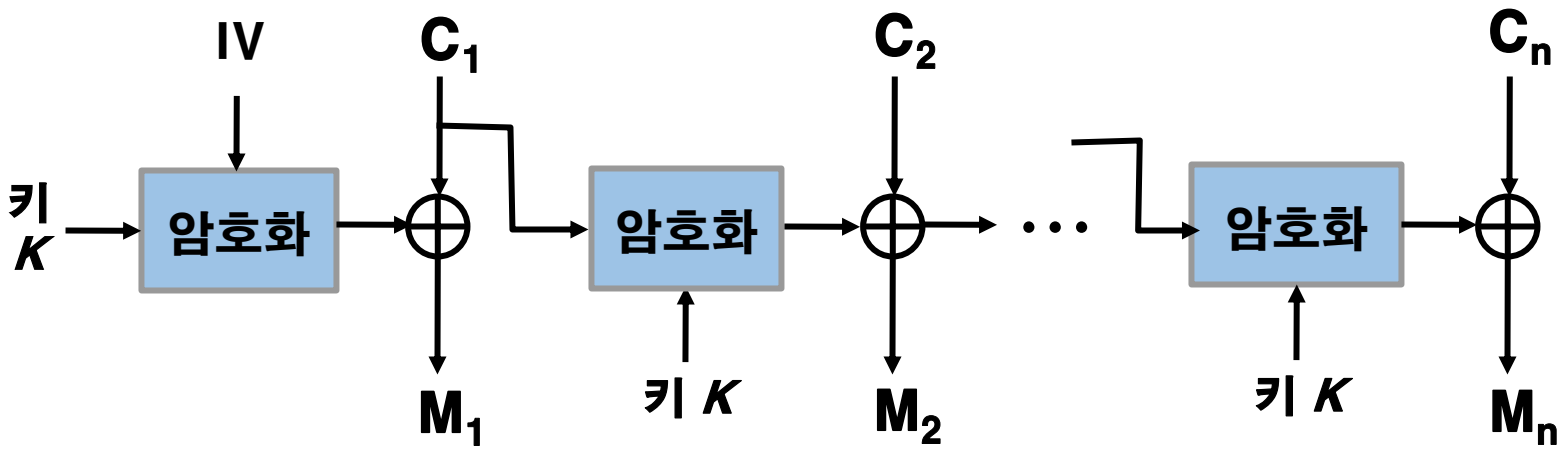
이전 암호문(ciphertext)을 다음 암호화의 입력으로 사용(feedback)



- 동일한 평문 블록에 대해 동일한 암호문이 나타나지 않음
- 평문 블록 내에 한 비트 오류가 발생하면 모든 암호문에 영향을 미침

3.3 블록 암호 – CFB 모드

복호화 $M_i = E_K(C_{i-1}) \oplus C_i$ 단, $C_0 = IV$



암호문 블록 내에 한 비트 오류가 발생하면 복호화 된 모든 평문에 영향을 미침

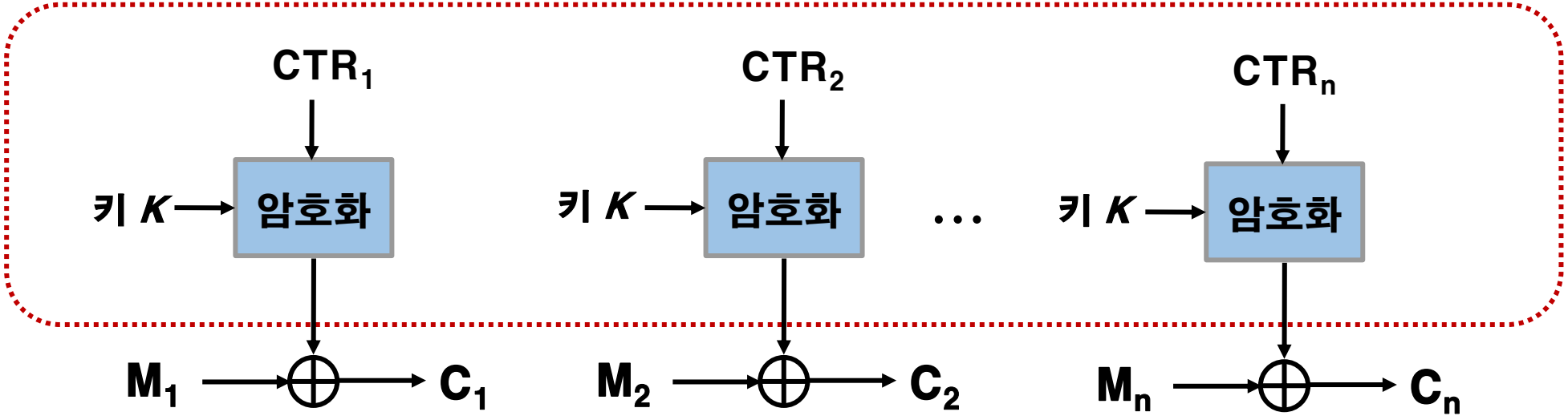
3.3 블록 암호 – CTR 모드

- **CTR(Counter) 모드**
  - 카운터(Counter) 모드
  - CFB 모드와 같이 블록 단위의 키 스트림 생성
  - 매번 달라지는 카운터 값을 블록 암호 시스템의 입력으로 사용

- **CBC나 CFB와 달리 피드백이 필요없기 때문에, 암호화가 병렬로 수행 가능 -> 고속 암호화 가능**

3.3 블록 암호 – CTR 모드

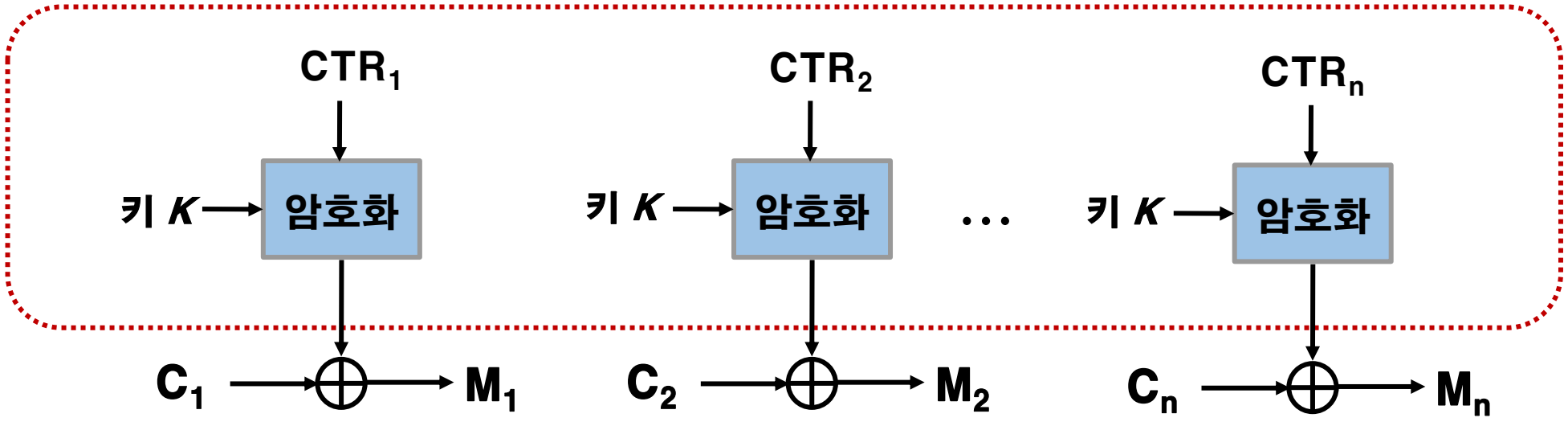
암호화 $C_i = E_K(CTR_i) \oplus M_i, \quad i \geq 1$



- 카운터 값은 순차적으로 증가하는 값으로 비밀일 필요는 없음
- 따라서, 송신자는 암호문 블록과 함께 수신자에게 전송하면 됨

3.3 블록 암호 – CTR 모드

복호화 $M_i = E_K(CTR_i) \oplus C_i, \quad i \geq 1]$



3.3 블록 암호 – CTR 모드

- 암호화와 복호화는 다수의 평문 또는 암호문 블록에 대해 **병렬 수행** 가능
- 블록 암호 알고리즘이 수행되는 부분이 평문이나 암호문에 영향을 받지 않음
  -> 메모리가 충분한 경우 **사전 계산 가능**
- 특정 블록에 대한 임의 접근 가능 -> **원하는 블록만 복호화 가능**
- ECB나 CBC 모드와 달리 암호화만 필요함

3.3 블록 암호 – 운영 모드 정리

운영 모드	특징	암호화 형태
ECB	• 각 블록에 동일한 키를 이용하여 독립적으로 암호화 수행 • 동일한 평문은 항상 동일한 암호문 생성(키 고정) • 짧은 길이의 평문을 암호화하는데 주로 사용	블록 암호
CBC	• 이전 블록의 암호문과 XOR 연산을 수행한 후 암호화 수행 • 동일한 평문도 암호화 할 때 마다 다른 암호문 생성(키 고정) • 평문 1비트의 변경이 암호문 마지막 비트까지 영향을 미침 -> 오류전파 특징(메시지 인증 코드로 사용)	블록 암호
CFB	• 암호화 함수의 출력을 다음 암호화의 입력으로 사용 • 동일한 평문도 암호화할 때 마다 다른 암호문 생성(키 고정) • 오류 전파특징	스트림 암호
CTR	• 매번 달라지는 카운터 값을 블록 암호의 입력으로 사용 • 동일한 평문도 암호화할 때 마다 다른 암호문 생성(키 고정) • IV와 CTR(카운터)는 비밀일 필요는 없음 • 암호화/복호화 병렬 수행 가능(고속 암호화 응용에 사용)	스트림 암호

3.4 무결성

➢ 기밀성과 무결성

- 기밀성은 권한이 없는 사람이 정보의 내용을 **알게 되는 것을 방지**
- 무결성은 권한이 없는 사람이 정보의 내용을 **변경하는 것을 탐지**

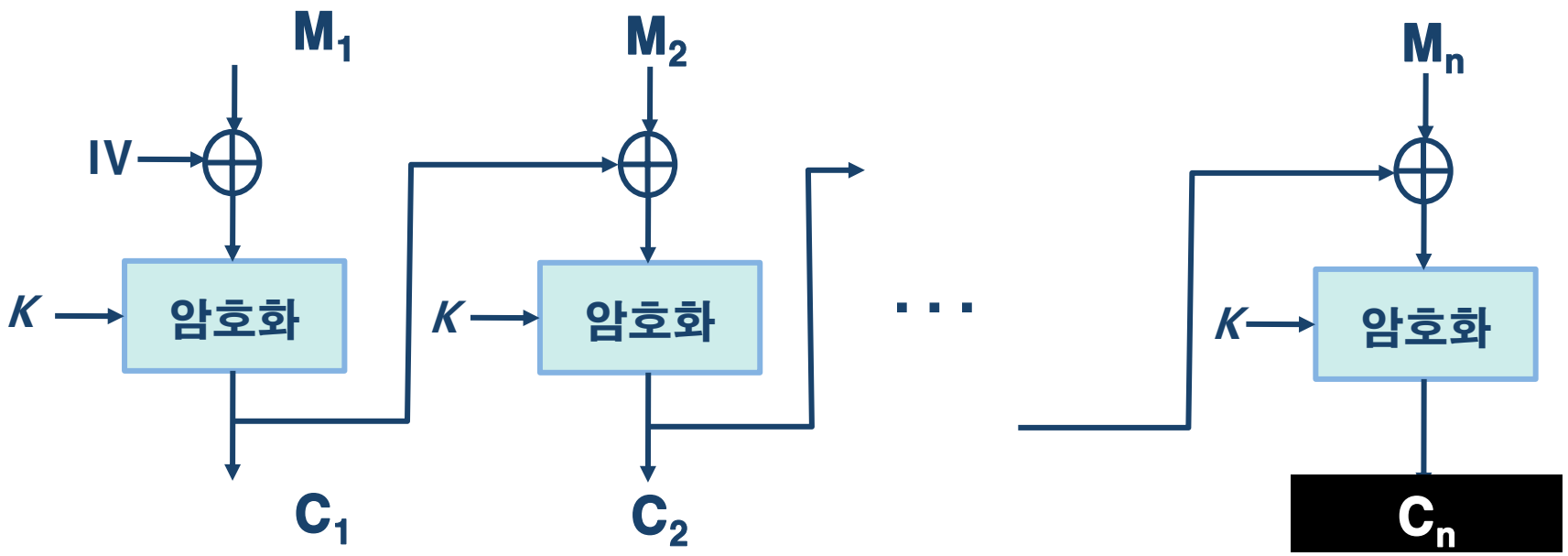
➢ 메시지 인증 코드(MAC, Message Authentication Code)

- 데이터의 무결성을 보장하기 위해 사용
- 블록 암호 시스템의 CBC 모드를 이용하여 생성 가능
  - CBC 모드를 이용한 암호화에서 평문의 변경은 마지막 블록까지 전파된다는 점을 이용

3.4 무결성

➢ 메시지 인증 코드를 생성하기 위해 블록 암호 알고리즘 사용

- 블록 암호 알고리즘의 CBC(Cipher Block Chaining) 모드를 이용하여 메시지를 암호화 한 후, 마지막 암호문 블록을 MAC으로 사용



메시지 인증코드(MAC)로 사용

3.4 무결성

➢ 메시지에 대한 무결성 보장만 요구되는 경우(기밀성은 보장되지 않음)

Alice(송신자)

(3) M || MAC →

Bob(수신자)

(1) 송신자는 메시지 M에 대해 K를 이용하여 CBC 모드로 암호화 수행
(2) 생성한 마지막 암호문 블록(MAC)과 메시지 전송

(4) K를 이용하여 M을 CBC 모드로 암호화 수행
(5) 자신이 생성한 마지막 암호문 블록과 수신한 MAC이 일치하는지 확인
(6) 일치하는 경우, 메시지 M의 무결성 확인

- M : 송신하려는 메시지
- K : Alice와 Bob 사이에 공유한 비밀키
- MAC : 블록 암호 시스템의 CBC 모드로 암호화 한 마지막 암호문 블록

3.5 양자 컴퓨터와 대칭 암호

➢ 양자 컴퓨팅

- 강력한 컴퓨터를 만들기 위해 양자역학의 특징을 이용하는 것
- 하나의 처리 장치에서 여러 계산을 동시에 처리할 수 있어 엄청난 성능 증가 가능

➢ 양자 컴퓨터와 대칭키 암호 시스템의 안전성

- 대칭키 암호 시스템의 키를 찾기위해 사용 가능한 최선의 양자 알고리즘은 1996년에 로브 그로버(Lov Grover)가 개발한 알고리즘
  - N비트의 키를 가진 대칭키 암호 시스템에 대해 키를 찾는데 요구되는 연산량을 $2^{n/2}$로 감소시킴
  - 128비트의 대칭키 암호 시스템은 안전하지 않음
- 키 길이가 긴 대칭키 암호 시스템을 개발하는 것은 어려운 일이 아니므로 대칭키 암호 방식에는심각한 위협이 되지는 않음
- 양자 컴퓨팅은 공개키 암호 시스템에 위협적

요약

- 대칭키 암호 방식은 스트림 암호와 블록 암호로 구분
  - 스트림 암호는 실용성을 위해 보안성이 다소 약화된 일회성 암호체계(One Time Pad)를 일반화한 암호 알고리즘임
    - 예) A5/1, RC4, Trivium 등
  - 블록 암호는 고전 코드북 암호의 전자화된 형태로 평문을 특정 크기의 블록으로 나누어 전치, 치환, XOR 연산 등을 반복하여 적용
    - 예) DES, AES, SEED, PRESENT, LEA 등

- 블록 암호 알고리즘을 사용하는 경우, 다양한 운영 모드를 선택할 수 있음
  - ECB, CBC, CFB CTR 모드 등
  - CBC 모드는 데이터 무결성을 제공하기 위해 사용할 수 있으며, CTR 모드는 고속처리가 필요한 환경에 적합